QUIZ 1

Multiple Choice

10 items | 1 point each

NAME _____ SECTION _____ SCORE _____

Directions: Read each question carefully. Write the letter of the best answer on the blank before each number.

_____ **1** **What is the core security assumption when building a React application?**

a. The server is a hostile environment
b. Treat the browser as a hostile environment
c. Third-party scripts are always trusted
d. React apps are secure by default

_____ **2** **Which is the ONLY place that can authoritatively enforce authorization?**

a. The React component
b. The browser's localStorage
c. The server
d. The CDN

_____ **3** **Which type of XSS never touches the server and is written into the DOM by client-side code through an unsafe sink?**

a. Stored XSS
b. Reflected XSS
c. DOM-based XSS
d. Persistent XSS

_____ **4** **Which React prop skips React's default escaping and renders raw HTML?**

a. `innerText`
b. `dangerouslySetInnerHTML`
c. `htmlContent`
d. `rawHTML`

_____ **5** **Which library is used to sanitize HTML before rendering it with dangerouslySetInnerHTML?**

a. Helmet
b. Dependabot
c. DOMPurify
d. Renovate

QUIZ 1 | Multiple Choice (continued)

_____ **6** **CSRF attacks most commonly ride along on which credential that the browser sends automatically?**

a. Session cookies
b. localStorage tokens
c. API keys in the bundle
d. Query parameters

_____ **7** **Which token storage option is NOT readable by JavaScript?**

a. localStorage
b. sessionStorage
c. IndexedDB
d. HttpOnly cookie

_____ **8** **Which cookie attribute makes the browser withhold the cookie on cross-site requests?**

a. `httpOnly`
b. `secure`
c. `sameSite: 'strict'`
d. `maxAge`

_____ **9** **Which security header blocks your site from being embedded in another site's iframe (the fix for clickjacking)?**

a. Referrer-Policy
b. X-Frame-Options / frame-ancestors
c. X-Content-Type-Options: nosniff
d. Strict-Transport-Security

_____ **10** **Which Express middleware sets sensible security header defaults in one call?**

a. cors
b. helmet
c. dotenv
d. morgan

QUIZ 2

Identification

10 items | 1 point each

NAME _____ SECTION _____ SCORE _____

Directions: Identify what is being described in each item. Write your answer on the line provided.

1. The type of XSS where the payload is saved on the server (e.g., a comment) and served to every visitor who views that content.

_____

2. The type of XSS where the payload is bounced straight back from a URL or query parameter.

_____

3. An attack that tricks a logged-in user's browser into sending a request without their knowledge.

_____

4. A broken access control vulnerability where any authenticated user can view another user's resource simply by changing the id in the URL (give the acronym).

_____

5. An attack where your site is embedded inside an invisible iframe layered under a fake UI so the victim's click lands on a hidden button.

_____

6. The security header that restricts which sources scripts and styles may load from, acting as a strong second layer of XSS defense.

_____

7. The security header that forces the browser to only ever connect over HTTPS for a domain (give the acronym or full name).

_____

8. A hash added to a third-party CDN script tag so the browser refuses to run a tampered file.

_____

9. The npm command used to check your project's dependencies for known vulnerabilities.

_____

10. The HTTP status code returned when the logged-in user does not own the requested resource.

_____

QUIZ 3

True or False

10 items | 1 point each

NAME _____ SECTION _____ SCORE _____

Directions: Write **TRUE** if the statement is correct and **FALSE** if it is incorrect on the blank provided.

ANSWER	NO.	STATEMENT
_____	1	React escapes rendered text by default, which already blocks a large class of attacks.
_____	2	A client-side role check is enough to secure a route, as long as the button is hidden in the UI.
_____	3	Storing a JWT in localStorage is safe because injected scripts cannot read it.
_____	4	sessionStorage has the same risk as localStorage, except it is cleared when the tab closes.
_____	5	An HttpOnly cookie cannot be stolen via XSS, but it must still be paired with CSRF defenses.
_____	6	It is safe to place a real secret key in a REACT_APP_* or VITE_* environment variable because it stays on the server.
_____	7	The .env file should be kept out of version control.
_____	8	Committing the lockfile ensures every install resolves to the versions you tested.
_____	9	A short-lived access token paired with a rotating refresh token is safer than one long-lived token.
_____	10	Third-party scripts like ads, analytics, or chat widgets do not share access to your DOM and storage.